

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Evaluación de 9 Criterios para Todas las Métricas EPSS

Versión: 1.0

Fecha: Enero 2026

Formato: Matriz evaluativa detallada

MATRIZ MAESTRO: MÉTRICAS EPSS vs CRITERIOS PRAGMATIC

Leyenda de Puntuación

- 1-3: Deficiente (no cumple criterio)
- 4-6: Moderado (cumple parcialmente)
- 7-8: Bueno (cumple con limitaciones menores)
- 9-10: Excelente (cumple completamente)

SECCIÓN A: GESTIÓN DE VULNERABILIDADES - EPSS

Métrica A1: Cobertura EPSS (% CVEs puntuados)

Criterio PRAGMATIC	Puntuación	Evaluación	Evidencia
Predictivo	8/10	↑ Cobertura EPSS predice capacidad detección futura	Si 90% CVEs tienen score, predice mejor monitoreo futuro
Relevante	9/10	Crítico para CISOs/auditores (compliance indicator)	NIS2 requiere "medidas basadas en riesgo probabilístico"
Accionable	8/10	Si cobertura <70%, acción: integrar API EPSS en VM tools	Clearmente determina si revisar stack técnico
Genuino	9/10	Mide exactamente "qué % de CVEs tienen predicción EPSS"	Definición operacional inequívoca
Significativo	7/10	Diferencia 60% – 80% es importante; 99% – 100% menos	Depende baseline actual
Preciso	9/10	Query automática en BD: COUNT(EPSS_score IS NOT NULL)/COUNT(*)	Medible sin ambigüedad
Oportuno	10/10	Actualización diaria (API EPSS refreshes daily)	Dato disponible en tiempo real
Independiente	8/10	Ligeramente afectado si cambia VM tool o feed EPSS	Control posible mediante documentación de cambios
Rentable	10/10	Costo recolección: €0 (es automático en tool)	Beneficio: alineación NIS2
PROMEDIO PRAGMATIC	8.7/10	EXCELENTE - Métrica de Clase A	Implementar sin vacilar

Métrica A2: MTTR Críticas (Vulnerabilidades EPSS≥0.50)

Criterio	Puntuación	Evaluación	Mejora Recomendada
Predictivo	7/10	MTTR pasado predice futuro si estable	Agregar trend mensual (slope)
Relevante	9/10	Directamente mapea a NIS2 Art 21(E) remediación	KPI de junta directiva
Accionable	9/10	Si MTTR > 7 días: auditar delays, escalar recursos	Muy claro qué mejorar
Genuino	7/10	Requiere definiciones precisas (detection ≠ remediation)	Crear diccionario de términos
Significativo	8/10	Cambios >5 días son operativamente importantes	Diferencia real en exposición
Preciso	6/10	Datos manuales de tickets pueden ser inconsistentes	Automatizar vía tickets API
Oportuno	8/10	Reportable mensualmente; ideal: semanal	Habilitar dashboards semanales
Independiente	5/10	Muy afectado por tamaño/turnover equipo remediación	Considerar análisis causal (regression)
Rentable	9/10	Costo: análisis mensual ~€500; ROI >100x	Inversión justificada
PROMEDIO	7.6/10	BUENA - Métrica de Clase B	Implementar con mejoras

Métrica A3: Efficiency EPSS (% Priorizadas que se explotan)

Criterio	Puntuación	Evaluación	Notas
Predictivo	9/10	Valida predictividad de modelo EPSS futuro	Excelente indicador de precisión modelo
Relevante	8/10	Importante para científicos datos/security eng	Menos visible para C-suite
Accionable	7/10	Si efficiency <50%, revisar modelo o data feeds	Requiere expertise técnica para actuar
Genuino	8/10	Mide "de vulnerabilidades que priorizamos, ¿cuántas explotan?"	Bien definido
Significativo	9/10	Diferencia 40% – 60% es operativamente crítica	Grandes implicaciones de precisión
Preciso	7/10	Requiere seguimiento de CVEs explotadas (KEV)	Posible sesgo en reporting
Oportuno	9/10	Calculable mensualmente desde KEV historical	Data pública disponible
Independiente	6/10	Afectado por cambios en KEV reporting methodology	Documentar cambios CISA
Rentable	8/10	Costo bajo; ROI medio (informativo, no directo)	Util para mejora continua modelo
PROMEDIO	7.9/10	BUENA - Métrica de Clase B+	Implementar como KPI técnico

SECCIÓN B: MONITOREO Y DETECCIÓN (SIEM)

Métrica B1: MTTD (Mean Time to Detect) - Incidentes EPSS-priorizados

Criterio	Puntuación	Evaluación
Predictivo	8/10	Histórico MTTD predice futura capacidad detección
Relevante	10/10	MÁXIMA relevancia: requiere GDPR Art 32, NIS2 Art 21(C)
Accionable	9/10	Si MTTD > 24 horas → auditar reglas SIEM, tuning
Genuino	7/10	Requiere definición precisa "evento detectado" vs "investigado"
Significativo	9/10	Diferencia 12h → 4h es enormemente importante
Preciso	5/10	Timestamp inconsistencias entre sistemas (timestamp drift)
Oportuno	8/10	Calculable en tiempo real desde SIEM
Independiente	4/10	Muy sensible a cambios reglas, tuning, alertas
Rentable	7/10	Costo: SIEM query; ROI: estimación breach prevention
PROMEDIO	7.5/10	BUENA - Métrica de Clase B

SECCIÓN C: RESPUESTA A INCIDENTES

Métrica C1: MTTE (Mean Time To Escalate) - a reguladores

Criterio	Puntuación	Evaluación
Predictivo	6/10	Histórico predice capacidad respuesta futuro
Relevante	10/10	MÁXIMA: NIS2 Art 19 requiere <24h notificación
Accionable	8/10	Si MTTE > 24h → revisar procedimiento escalación
Genuino	9/10	Métrica legal/regulatoria bien definida
Significativo	10/10	Cumplimiento <24h vs incumplimiento es crítico
Preciso	8/10	Auditable; timestamps en tickets/logs
Oportuno	7/10	Reportable post-incidente (no en tiempo real)
Independiente	3/10	Muy dependiente de proceso/procedimiento manual
Rentable	8/10	Bajo costo; ROI: evitar multa €5M-50M+
PROMEDIO	7.7/10	BUENA - Métrica de Clase B

SECCIÓN D: CAPACITACIÓN Y CONCIENCIA

Métrica D1: Phishing Click Rate (%) - empleados

Criterio	Puntuación	Evaluación
Predictivo	8/10	Click rate predice susceptibilidad futura a phishing
Relevante	9/10	90% incidentes tienen componente humano (alta relevancia)
Accionable	9/10	Si >20% click: intensificar capacitación, MFA
Genuino	7/10	Mide comportamiento, pero puede estar sesgado (empleados saben es simulado)
Significativo	8/10	Cambio 35% → 12% es operativamente importante
Preciso	8/10	Automatizado en plataforma phishing (high precision)
Oportuno	9/10	Datos disponibles inmediatamente post-campaña
Independiente	6/10	Afectado por fatiga laboral, timing campaña, dificultad email
Rentable	9/10	Bajo costo (€2K/año plataforma); ROI: prevención breach
PROMEDIO	8.1/10	BUENA - Métrica de Clase A-

SECCIÓN E: GOBERNANZA Y CUMPLIMIENTO

Métrica E1: % Decisiones Priorización documentadas con EPSS

Criterio	Puntuación	Evaluación
Predictivo	5/10	No predice, pero documenta conformidad histórica
Relevante	10/10	Crítico para auditoría NIS2/GDPR (trazabilidad)
Accionable	7/10	Si <80%, mejorar documentación proceso de priorización
Genuino	9/10	Bien definido: ¿existe documentación de EPSS en decisión?
Significativo	10/10	Diferencia entre 50% vs 100% documenta vs no documenta
Preciso	8/10	Auditable via ticket review
Oportuno	6/10	Auditoría retrospectiva (post-evento)
Independiente	7/10	Bajo sesgo si proceso auditoria es consistente
Rentable	10/10	Costo: auditoría manual; ROI: defensa legal
PROMEDIO	7.8/10	BUENA - Métrica de Clase B+

TABLA RESUMEN: COMPARATIVA TODAS MÉTRICAS

Métrica	Predictivo	Relevante	Accionable	Genuino	Significativo	Preciso	Oportuno	Independiente	Rentable	PRO MEDIO	Clase
A1: Cobertura EPSS	8	9	8	9	7	9	10	8	10	8.7	A
A2: MTTR Críticas	7	9	9	7	8	6	8	5	9	7.6	B
A3: Efficiency EPSS	9	8	7	8	9	7	9	6	8	7.9	B+
B1: MTTD	8	10	9	7	9	5	8	4	7	7.5	B
C1: MTTE	6	10	8	9	10	8	7	3	8	7.7	B
D1: Phishing Click	8	9	9	7	8	8	9	6	9	8.1	A-
E1: Documentación	5	10	7	9	10	8	6	7	10	7.8	B+

RECOMENDACIONES POR CLASE

Clase A (8.5-10/10): Implementar inmediatamente (son "métricas de oro")

- Cobertura EPSS (A1): 8.7/10
- Phishing Click Rate (D1): 8.1/10 (upgrade a A si mejoras precisión)

Clase B (7.0-8.4/10): Implementar con mejoras documentadas

- MTTR Críticas (A2): 7.6/10
- Efficiency EPSS (A3): 7.9/10
- MTTD (B1): 7.5/10
- MTTE (C1): 7.7/10
- Documentación (E1): 7.8/10

Clase C (<7/10): Reconsiderar o mejorar antes de implementar

- (Ninguna en este set inicial)

*Matriz PRAGMATIC desarrollada por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*